



Formation Kubernetes

Session 6 — Secrets Avancés : ESO et Vault

Reflekt Lab | 22h de formation | 11 sessions

Agenda de la session



Recap S5 + ESO

Limites CSI, introduction External Secrets Operator

10 min



Architecture ESO

SecretStore, ExternalSecret, Workload Identity, refresh

20 min



Panorama Vault

Vault, VSO, OpenBao, Dynamic Secrets — quand l'utiliser

15 min



Production RFLKT

Cas reels : rotation DB, third-party APIs, incident response

10 min



TP : ESO en action

SecretStore + ExternalSecret + auto-sync + rotation live

50 min



Pièges et récap

refreshInterval, pod reload, debug ESO

15 min

Recap — Session 5



Le problème

Hardcoded → fuite via git, kubectl, CI logs. base64 ≠ chiffrement.



K8s Secrets natifs

Stockés en clair dans etcd, gestion manuelle, pas de rotation



CSI Secret Store

Mount-as-file depuis GCP Secret Manager. Pas de Secret K8s, audit dans GCP.

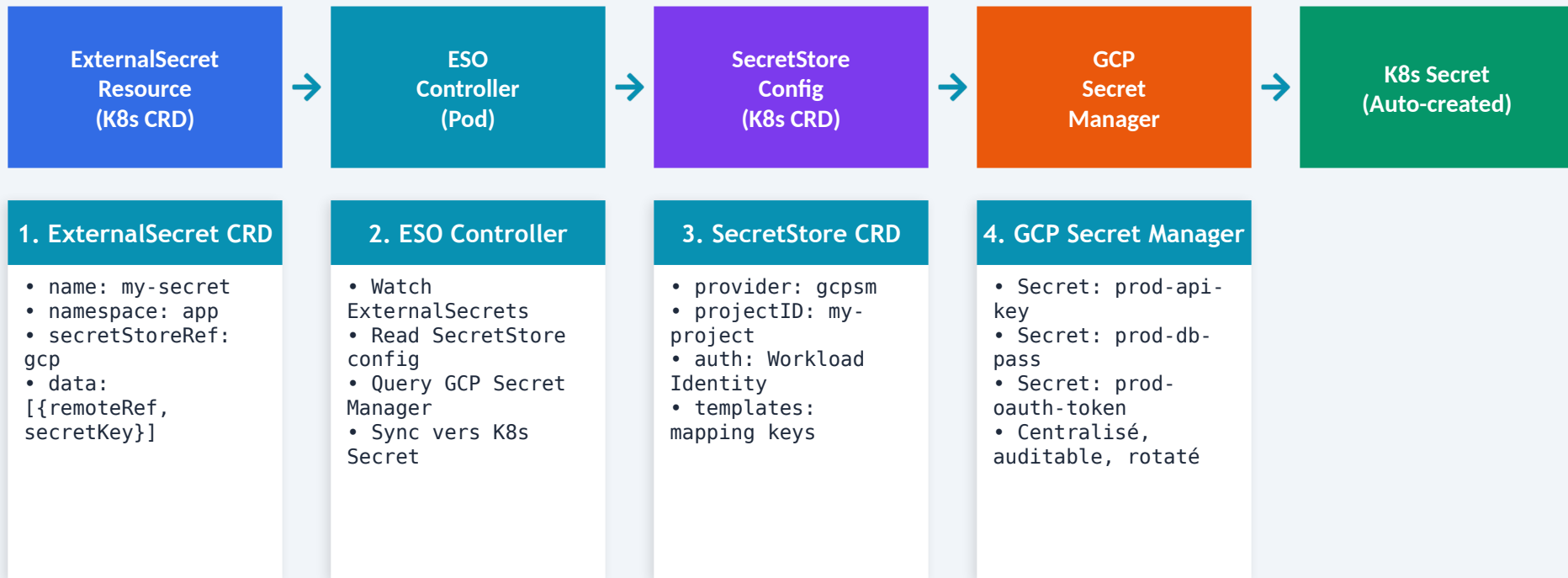


Limite du CSI

Bien pour fichiers ; mais ne crée pas de K8s Secret → pas d'env vars sync auto

Session 6 : Automatiser la synchronisation et la rotation des secrets

External Secrets Operator – Architecture



SecretStore & ExternalSecret – Anatomie

```
apiVersion: external-secrets.io/v1
kind: SecretStore
metadata:
  name: gcp-secret-store
  namespace: exercices
spec:
  provider:
    gcpsm:
      projectID: my-gcp-project
      auth:
        workloadIdentity:
          clusterLocation: europe-west9
          clusterName: my-cluster
          serviceAccountRef:
            name: eso-sa
```

projectID : GCP project où vivent les secrets

Workload Identity : auth sans clé API

```
apiVersion: external-secrets.io/v1
kind: ExternalSecret
metadata:
  name: prod-api-secret
spec:
  refreshInterval: 1h
  secretStoreRef:
    name: gcp-secret-store
  target:
    name: api-credentials
  creationPolicy: Owner
  data:
    - secretKey: API_KEY
      remoteRef:
        key: prod-api-key
```

refreshInterval : resync toutes les 1h (default)

remoteRef ↔ secretKey : mapping GCP → K8s Secret

Refresh automatique – Auto-sync de GCP vers K8s

T=0



Changement secret dans GCP

T+5s



ESO detect (watch ou polling)

T+10s



K8s Secret mis à jour

T+15s



Pod recharge env vars (si déploiement rolling restart)

T+20s



App utilise le nouveau secret

refreshInterval: 1h (défaut) | Min: 15s, Recommended: 1h+

Plus court = charge GCP ↑ , coût ↑ | Plus long = delay de rotation ↑

CSI Secret Store vs External Secrets Operator

Critère	CSI Secret Store	External Secrets Operator
Stockage	Aucun (volume mount direct)	K8s Secret (etcd)
Sync	Au mount du pod (lancement)	Périodique (1h défaut)
Env vars	Non (fichier uniquement)	Oui (K8s Secret → env)
Pod reload	Auto (fichier change)	Manuel (restart deploy)
Coût	Faible (1 API call / pod start)	Moyen (1 call / interval)
Compliance	Zéro trace K8s Secret	Trace dans etcd (chiffrer !)
Use-case	Fichiers config, certs	Env vars, rotation auto

Règle d'or : CSI pour fichiers, ESO pour env vars + rotation auto

HashiCorp Vault – Architecture & Use-cases

Vault Server

- Storage : Raft intégré (défaut) ou Consul/S3/GCS
- Secret engines : KV, PKI, SSH, DB
- Auth methods : Kubernetes, JWT, LDAP
- Policies : RBAC fine-grained

Intégration K8s

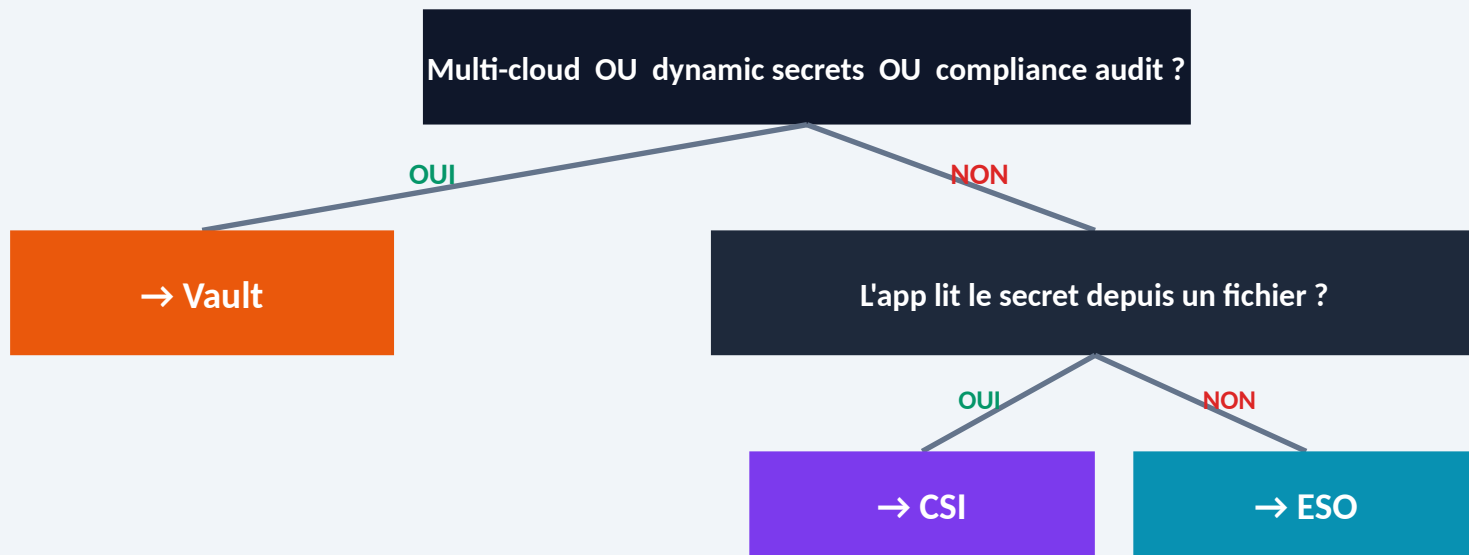
- Vault Secrets Operator (VSO) — CRD natif, recommandé
- Vault Agent Injector — sidecar via webhook (legacy)
- Auto-renew token + rotation
- Secret template rendering

Dynamic Secrets

- Credentials générées à la demande
- TTL court (ex: 1h)
- Auto-revoke : plus besoin de rotation
- Audit complet : qui a généré quoi

Vault = Gestionnaire de secrets centralisé pour toute l'infrastructure (pas juste K8s)

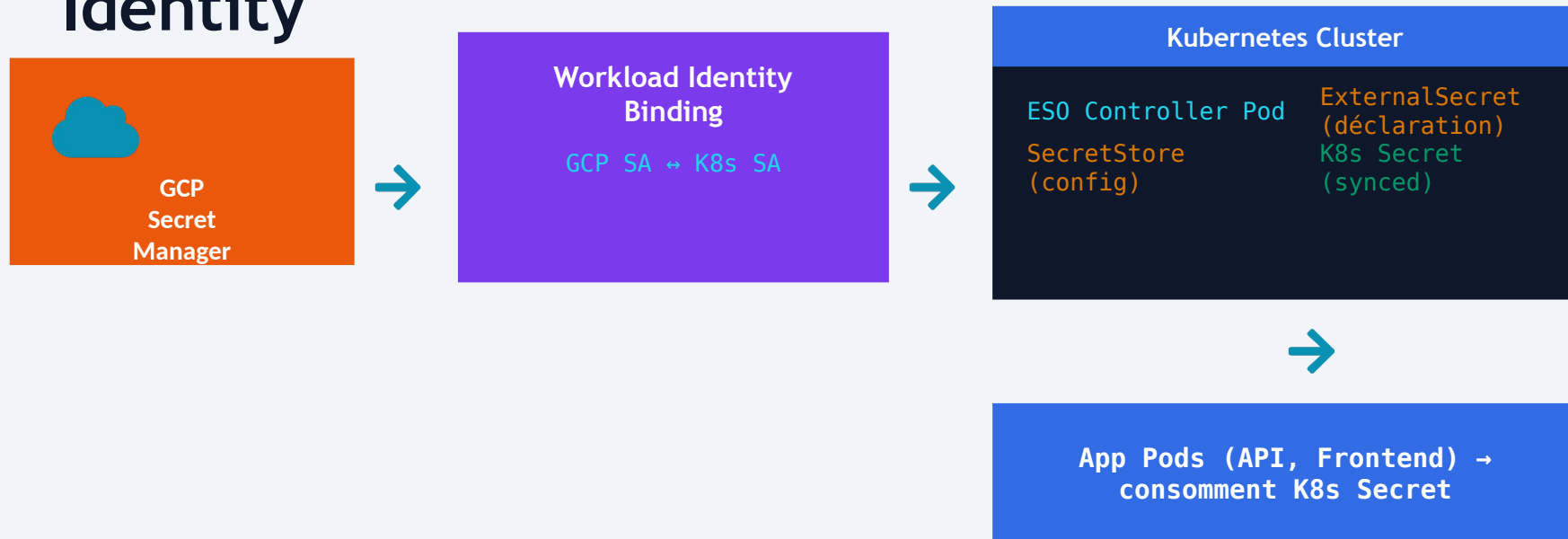
Matrice de décision : Quel tool choisir ?



CSI = Fichiers, pas de pod reload | **ESO** = Env vars, rotation auto simple | **Vault** = Secrets dynamiques, multi-cloud, compliance strict

RFLKT utilise principalement ESO (simple + efficace pour notre cas). Vault serait nécessaire si on était multi-cloud.

Architecture du TP – ESO avec Workload Identity



Étapes du TP

Pre-installe par le formateur : ESO, GCP SA training-apps, Workload Identity binding, secrets GCP

1. Créer SecretStore-<NOM> avec provider gcpsm + serviceAccountRef: training-apps
2. Créer ExternalSecret-<NOM> qui pointe au SecretStore et liste les remoteRefs GCP
3. Vérifier que ESO crée le K8s Secret api-secrets-<NOM> et déployer l'app (envFrom)
4. Observer la rotation (formateur change le secret GCP → propagation < 1 min)

Production RFLKT — Cas reels

Rotation password Cloud SQL

Cloud SQL admin rotate le password → nouveau secret dans GCP Secret Manager → ESO sync (1 min) → rollout restart des API qui lisent en env. Zero downtime si replicas ≥ 2.

Cle API third-party (Stripe, SendGrid)

Dashboard du fournisseur génère une nouvelle clé → ops écrit la valeur dans GCP Secret Manager → ESO propage. Pas de redéploiement Docker, pas de PR. Audit trail dans GCP.

Multi-environment (staging / prod)

Un SecretStore par env (staging-secret-store, prod-secret-store) référencant des projets GCP distincts. Les ExternalSecrets staging ne peuvent pas lire les secrets prod (IAM séparé).

Incident : secret leak detected

PagerDuty alert → ops révoque la cle compromise (API tier) + crée une nouvelle version dans GCP → ESO propage. SLO de remediation : < 5 minutes pod-side avec refreshInterval=1m.

Compliance & audit

GCP Cloud Logging : qui a accédé à quel secret, quand. SOC2 / ISO27001 friendly. Aucun secret en clair dans git ou Terraform state.

Tout ça est defini en Terraform dans `cloud-infrastructure/modules/external_secrets/`

Pièges et bonnes pratiques ESO/Vault

refreshInterval trop court

Requêtes fréquentes à GCP = dépassement quota + coût API. Min 15s, recommandé 1h+

Solution :

Ajuster selon la criticité : 1h pour config, 15m pour API key sensible

Pod ne recharge pas secret

K8s Secret mis à jour mais le pod a la vieille valeur en mémoire (env vars statiques)

Solution :

Faire un rolling restart : `kubectl rollout restart deployment/api`

SecretStore non-trouvée

ExternalSecret en namespace A pointe à SecretStore en namespace B → erreur silencieuse

Solution :

SecretStore et ExternalSecret même namespace, ou utiliser ClusterSecretStore

Workload Identity binding oubliée

ESO pod peut pas requête GCP (permission denied), secret reste manquant

Solution :

Vérifier : `kubectl describe pod ESO-POD | grep gcp-service-account`



Récap & Mini-défi



ESO : Sync automatique des secrets GCP → K8s Secret



RefreshInterval : rotation auto-périodique sans intervention



SecretStore : config du provider (GCP, Vault, AWS...)



ExternalSecret : déclaration des secrets à syncer + mapping

Mini-défi pour la prochaine session

1. Recherchez 3 use-cases où Vault est meilleur que ESO/CSI
(Multi-cloud ? Dynamic secrets ? Compliance ? SSH certs ?)
2. Imaginez une architecture Vault pour gérer secrets de 3 datacenters différents
3. Répondez : dans notre cas RFLKT (single cloud), pourquoi ESO est-elle bonne ?